FortiBleed: credenziali rubate, firewall FortiGate bloccati e accessi venduti a gruppi RaaS

Autore: Alessio Lacava | Data: 20 ottobre 2026 | Analisi basata su fonti pubbliche

1. Sintesi

FortiBleed è una campagna di compromissione di credenziali contro firewall e gateway VPN SSL **Fortinet FortiGate** esposti a internet.
Il 6 ottobre 2026 FBI e US Secret Service hanno pubblicato un avviso congiunto (JCSA-20261006-01): la campagna è ancora attiva, può **bloccare gli amministratori** fuori dai loro dispositivi e gli Initial Access Broker (cybercriminali che violano le reti aziendali non per attaccarle direttamente, ma per rivenderne l'accesso pronto all'uso) hanno passato l'accesso ad **affiliati di gruppi RaaS (Ransomware-as-a-Service)** come INC/Lynx e Payload.

L'avviso cita la verifica di SOCRadar: **oltre 86.644 dispositivi compromessi in 194 paesi**. Il CISO di SOCRadar ha dichiarato a CyberScoop che l'operazione più ampia ha preso di mira tra 400.000 e 450.000 firewall. Le cifre non sono purtroppo confrontabili: alcune contano i dispositivi compromessi, altre i bersagli dei tentativi o le singole credenziali raccolte.

Secondo l'avviso, la campagna sfrutta credenziali riutilizzate o trapelate e la **memorizzazione delle password con SHA-256 legacy**, che permette di raccogliere e decifrare i dati di autenticazione su larga scala. Fortinet ha dichiarato il 19 giugno 2026 che non si tratta di una nuova vulnerabilità. L'operazione è diventata visibile perché gli attaccanti hanno esposto per errore il proprio server: la directory aperta ha rivelato gli strumenti, tra cui un cluster GPU distribuito per il cracking delle password.

2. Catena d'attacco

Fase	Evidenza riportata	Fonte	Affid.
Initial Access	Scansione di internet per portali SSL VPN FortiGate esposti, poi credential stuffing e password spraying con vecchi dump Fortinet e log di infostealer.	Avviso FBI/USSS, Fortinet PSIRT, Infosecurity Magazine	Alta
Credential Access	Gli hash delle password vengono estratti dai dispositivi compromessi; secondo l'avviso anche database utenti FortiOS e token di sessione, inviati di continuo a server degli attaccanti.	Avviso FBI/USSS, Help Net Security, CSA	Alta
Cracking offline	Gli hash vengono decifrati su un cluster GPU con Hashcat, orchestrato da Hashtopolis; le credenziali ottenute sono validate, honeypot filtrati e i bersagli ordinati per fatturato e struttura di rete.	Avviso FBI/USSS, Help Net Security, Infosecurity Magazine, CSA	Alta

Fase	Evidenza riportata	Fonte	Affid.
Persistence / Lockout	Creazione di nuovi account amministrativi; in alcuni casi gli account originali vengono cancellati o la loro password cambiata, con blocco degli amministratori. Anche SSH può essere abusato se la porta è aperta sul firewall.	Avviso FBI/USSS, Help Net Security, CyberScoop	Alta
Discovery	Con credenziali verificate gli attaccanti entrano negli ambienti delle vittime, enumerano gli account di Active Directory e provano password spraying per trovare account privilegiati.	Avviso FBI/USSS, Help Net Security, Infosecurity Magazine, CSA	Alta
Monetizzazione	L'accesso avviene con configurazioni VPN funzionanti ed elenchi di bersagli. Poi venduto ad altri attori	Avviso FBI/USSS, CyberScoop, Infosecurity Magazine, Help Net Security	Alta

Affidabilità: Alta = riportata dall'avviso congiunto e da almeno un'altra fonte;

3. Mappatura MITRE ATT&CK (Valutazione personale)

Tattica	ID	Tecnica	Uso
Resource Development	T1583	Acquire Infrastructure	Infrastruttura GPU noleggiata per il cracking
Reconnaissance	T1595	Active Scanning	Scansione dei portali SSL VPN
Initial Access	T1190	Exploit Public-Facing Application	Attacco ai dispositivi FortiGate esposti
Credential Access	T1110.004	Brute Force: Credential Stuffing	Credenziali di violazioni precedenti
Credential Access	T1110.003	Brute Force: Password Spraying	Password comuni su molti account
Credential Access	T1003	OS Credential Dumping	Database utenti FortiOS e token di sessione
Credential Access	T1110.002	Brute Force: Password Cracking	Cracking offline degli hash rubati
Persistence	T1136.001	Create Account: Local Account	Nuovi admin sul firewall
Initial Access	T1078	Valid Accounts	Credenziali verificate per entrare nelle reti
Discovery	T1087	Account Discovery	Enumerazione di Active Directory
Exfiltration	T1041	Exfiltration Over C2 Channel	Credenziali inviate a server degli attaccanti
Impact	T1531	Account Access Removal	Amministratori bloccati fuori

4. Cosa cercare nei log (idee di detection)

- **Account inattesi:** utenti amministrativi senza una richiesta di modifica corrispondente. L'avviso elenca 19 nomi di account osservati sui sistemi delle vittime (per esempio *forticloud-sync, support_fortinet, adminsslvpn, fortiAdmin, system_config*) e Fortinet aggiunge *forticloud, fortiuser, fortinet-support* e *fortinet-tech-support*. Nomi comuni come "admin" vanno verificati, non trattati come allarme automatico.
- **Account cancellati o password cambiate:** modifiche agli account amministrativi esistenti, o blocchi inattesi, da trattare come possibile compromissione e non come un ticket di supporto.
- **Spraying seguito da successo:** molti login falliti sul portale SSL VPN da pochi IP o su molti utenti, seguiti da un accesso riuscito.
- **Accessi amministrativi anomali:** login admin da IP o paesi insoliti, SSH verso il firewall, interfaccia di gestione raggiungibile da internet.
- **Nuove chiavi API REST:** chiavi che nessuno sa attribuire.
- **Dietro il firewall:** enumerazione degli account Active Directory, password spraying verso account privilegiati e movimento laterale verso server interni subito dopo un accesso VPN sospetto. L'avviso suggerisce di rivedere i log di firewall, VPN, autenticazione e domain controller.

I nomi esatti dei log e degli eventi dipendono dalla versione di FortiOS e dalla configurazione dei log. L'avviso elenca anche indirizzi IP con le finestre di osservazione (giugno-luglio 2026) e avverte che possono essere stati riassegnati: vanno verificati prima di bloccarli.

5. Mitigazioni indicate dall'avviso e da Fortinet

- Limitare l'amministrazione: host fidati (buono), policy local-in (meglio) o rimozione dell'amministrazione da internet (ottimo).
- Terminare tutte le sessioni amministrative e VPN, reimpostare tutte le password VPN e imporre policy di password robuste.
- Richiedere MFA resistente al phishing su tutti gli accessi remoti e amministrativi, applicata a ogni gateway esterno e interfaccia di gestione.
- Verificare che le password amministrative siano memorizzate con PBKDF2 e rimuovere gli hash legacy più deboli.
- Controllare tutte le chiavi API REST, rimuovere quelle sconosciute e rinnovare quelle legittime.
- Se emergono modifiche non autorizzate, trattare il dispositivo come compromesso (Fortinet rimanda a una guida di recupero dedicata).
- Risposta all'incidente: isolare gli host coinvolti, eseguire analisi di threat hunting per definire la portata e applicare le misure di eviction dopo aver raccolto dati sufficienti, per esempio con l'Eviction Strategies Tool di CISA. Il ripristino può richiedere interventi oltre la patch e il reset delle password.

6. Impatto e rilevanza strategica

Un firewall compromesso non è solo una perdita di controllo sul proprio perimetro. L'avviso riporta che gli initial access broker che usano questa catena hanno fornito accesso ad affiliati di gruppi ransomware: chi ottiene l'ingresso e chi cifra la rete possono essere attori diversi. Per questo il controllo di account amministrativi, accessi VPN e configurazione del firewall va trattato come **prevenzione del ransomware, non solo semplice sicurezza dell'accesso**.

7. Limiti della ricerca

- Solo fonti pubbliche: nessun log reale analizzato e nessun indicatore verificato di persona.
- Cifre discordanti: i numeri sui dispositivi dipendono da cosa analizza ciascuna fonte.
- Campagna in evoluzione: i dati possono cambiare dopo il 20 ottobre 2026.

8. Fonti

1. FBI e US Secret Service, Joint Cybersecurity Advisory JCSA-20261006-01, FortiBleed Operations Continue Targeting Exposed Systems Leading to Reports of Lockouts, 6 ottobre 2026. https://www.ic3.gov/CSA/2026/261006.pdf
2. Fortinet PSIRT (Carl Windsor), Analysis of Reported Credential Compromise of FortiGate Devices, 19 giugno 2026. https://www.fortinet.com/blog/psirt-blogs/analysis-of-reported-credential-compromise-of-fortigate-devices
3. Help Net Security, FortiBleed is still active, with attackers locking admins out of Fortinet firewalls, 7 ottobre 2026. https://helpnetsecurity.com/2026/10/07/fortinet-fortibleed-campaign-fbi-advisory
4. Infosecurity Magazine, FBI and Secret Service Warn of FortiBleed Lockout Threat, ottobre 2026. https://www.infosecurity-magazine.com/news/fbi-secret-service-fortibleed/
5. CyberScoop, Alert: FortiBleed remains active campaign, can lock out users or lead to ransomware attacks, ottobre 2026. https://cyberscoop.com/fortibleed-fortinet-vpn-ransomware-fbi-warning/
6. Cloud Security Alliance, FortiBleed: Credential Campaign and Admin Lockout at the Perimeter, 9 ottobre 2026. https://labs.cloudsecurityalliance.org/research/csa-research-note-fortibleed-credential-campaign-20261009-cs/